Arcanum: A Dual-Tier Stateless Air-Gapped and Split-VM Architecture for Kleptography-Resistant Zero-Knowledge Proofs

Architectural Specification & Security Model — Version 1.3

Mert Atakan
Conceptual Framework & Protocol Design
ORCID: 0009-0008-4681-7186

M. Zidan Fatonie
Systems Architecture & Verifier Infrastructure
Tawf Labs

Anjul Khatri
Cryptographic Proofs, Circuit Formalization
& Split-VM Isolation Architecture

November 2026

Abstract

Zero-Knowledge Proof (ZKP) systems allow a prover to demonstrate knowledge of a secret witness w satisfying a relation $\mathcal{R}(x, w) = 1$ without revealing w to the verifier. However, all standard ZKP toolchains implicitly assume that the proving software stack, compiler pipeline, and underlying host operating system are completely honest and isolated from network exfiltration. In practice, two catastrophic vulnerabilities undermine this assumption: (1) during proof generation, the plaintext witness vector resides exposed in the RAM of network-connected hosts, and (2) a compromised software dependency or malicious circuit compiler can mount a *kleptographic (subliminal channel) attack*, embedding secret witness bits directly inside the mathematical randomness of a valid proof.

In this paper, we present **Arcanum (v1.3)**, an open-source, defense-in-depth execution and sanitization architecture based on the Air-Gapped Zero-Knowledge Proof (**AG-ZKP**) paradigm. Arcanum introduces a **Dual-Tier Isolation Model** that achieves near-native proving speeds without the $10{,}000\times$ to $100{,}000\times$ computational penalty of Fully Homomorphic Encryption (FHE). **Tier-1 (Virtual Air-Gap)** isolates the prover on a single physical machine using a networkless Virtual Machine (`KVM/QEMU` or `Qubes OS`) hardened via `mlock`, swap elimination, CPU core pinning, Simultaneous Multithreading (SMT) deactivation, and optional hardware Trusted Execution Environments (`AMD SEV-SNP`, `Intel TDX`), connected to a network-facing *Sanitizer VM* exclusively via a unidirectional write-only channel (`vsock`, `virtio-serial`, or a read-only `shared-memory ring buffer`). **Tier-2 (Physical Air-Gap)** enforces two-device physical separation via a unidirectional optical data diode (screen-to-camera QR streaming). Across both tiers, the untrusted Sanitizer enforces **Dual-Track Kleptographic Elimination**: pairing-based proofs (Groth16) undergo cryptographic proxy rerandomization, while hash-based proofs (STARKs/Cairo) enforce Deterministic Fiat-Shamir derivation with channel binding.

Keywords: Zero-Knowledge Proofs, Kleptography, Subliminal Channels, Split-VM Isolation, KVM/QEMU, Qubes OS, Groth16 Rerandomization, Deterministic Fiat-Shamir, STARKs, Optical Data Diode.

Repositories & License: Code licensed under **GNU AGPLv3** (`https://github.com/Sidistr/Arcanum` and `https://github.com/Sidistr/ag-zkp`); specification released under **CC BY 4.0**.

1 Introduction and Threat Landscape

Modern cryptographic protocols rely heavily on Zero-Knowledge Proofs (ZKPs) for verifiable computation, privacy-preserving identity (ZK-KYC), Layer-2 validity rollups (such as Starknet), and enterprise state verification. While the mathematical soundness and zero-knowledge properties of protocols like Groth16, PLONK, and STARKs are rigorously proven in the abstract, their real-world deployments remain vulnerable to system-level and supply-chain compromise.

1.1 The Networked RAM Exposure Problem

During standard proof generation, a circuit compiler (e.g., Circom, Cairo, Noir) and witness generator must evaluate constraints over the secret input w in plaintext to populate the full witness vector $\mathbf{w} = (1, x_1, \ldots, x_m, w_1, \ldots, w_n)$. On any network-connected machine or conventional cloud server, this witness vector remains exposed in volatile memory, operating system swap files, or crash dumps. Recent enterprise infrastructure failures—such as the industry-wide abandonment of false cloud-managed "air-gap" backup architectures following the ConnectWise management-plane compromises—demonstrate that logical software toggles on network-connected hosts do not constitute true isolation.

1.2 The Supply-Chain Kleptography Problem

Even if a prover machine is placed behind a strict firewall, software supply-chain attacks against package registries (Cargo, npm, PyPI) or precompiled proving binaries introduce a deeper cryptographic threat first formalized by Young and Yung: **kleptography**.

A randomized ZKP protocol relies on internal entropy $r \leftarrow \$\mathcal{E}$ to blind the proof π. A maliciously modified proving library can replace truly random sampling with a deterministic subliminal encoding function:

$$r^* = \mathsf{Encode}_{\mathsf{pk}_{\mathsf{adv}}}(w, \mathsf{state}) \tag{1}$$

such that the resulting proof $\pi^* = \mathsf{Prove}(\mathsf{pk}, x, w; r^*)$ passes the standard verification equation $\mathsf{Verify}(\mathsf{vk}, x, \pi^*) = 1$ with probability 1, yet allows an external adversary observing π^* on a public blockchain or verification server to extract the secret witness w.

1.3 Limitations of Existing Countermeasures

Existing approaches fail to simultaneously resolve networked memory exposure, supply-chain kleptography, and performance feasibility:

2 Arcanum Dual-Tier Isolation Architecture

To serve both high-throughput automated enterprise/consumer environments and sovereign defense-grade deployments without forcing all users to purchase secondary hardware, Arcanum v1.3 defines a unified two-tier isolation architecture.

Approach	Host & Side-Channel Risk	Kleptographic Resistance	Performance Overhead
Standard ZKP Stack	Critical (Plaintext witness in networked RAM/swap)	None (Subliminal channels in proof randomness)	$1\times$ (Baseline)
Standalone Hardware TEE	High (Vulnerable to L1/L2 cache & microarchitectural attacks)	None (Malicious enclave code leaks via valid proof bytes)	$1.2\times - 3\times$
Fully Homomorphic (FHE)	Low (Encrypted evaluation)	Partial (Ciphertext metadata channels remain)	$10{,}000\times - 100{,}000\times$
Arcanum (Tier-1 Split-VM)	Mitigated (`no-NIC`, `mlock`, CPU pinning, SMT off, TEE)	**Full** (Sanitizer VM Rerandomization / Det. FS)	$\mathbf{1.05}\times - \mathbf{1.15}\times$
Arcanum (Tier-2 Optical)	Eliminated (Physical two-device air-gap + QR diode)	**Full** (External Proxy Sanitization + Channel Bind)	$\mathbf{1.05}\times$ + QR stream

Table 1: Comparison of Arcanum Dual-Tier Architecture against existing privacy and isolation paradigms.

2.1 Tier-1: Single-Machine Split-VM Architecture (Virtual Air-Gap)

Designed for single-machine deployments, developer workstations, enterprise server racks, and privacy-focused desktop environments, Tier-1 partitions a single physical host into two strictly separated virtual domains using `KVM/QEMU` or `Qubes OS`:

1. **Networkless Prover VM (`no-NIC` Domain):** The proving engine executes inside an isolated Virtual Machine provisioned with zero virtual or physical network interfaces. The Prover VM cannot initiate or receive TCP/IP, UDP, or socket connections to the outside world.

2. **Circuit & Witness Execution Pipeline (Circom / R1CS / STARK Flow):** To maintain a minimal and auditable attack surface inside the isolated environment, circuit compilation is decoupled from witness evaluation:

   - Compiled circuit constraints—such as Rank-1 Constraint System (`R1CS`) binaries or arithmetic execution traces—along with the deterministic witness generation code are exported from the build environment and mounted inside the Prover VM as a read-only image.
   - Private inputs w are supplied exclusively inside the Prover VM (stored on an encrypted disk volume attached solely to that VM).
   - The witness generator populates the witness vector $\mathbf{w} \in \mathbb{F}_p^m$ satisfying $\mathbf{Aw} \circ \mathbf{Bw} = \mathbf{Cw}$ and passes $\mathbf{w}$ directly in locked memory to the proving engine to produce the raw proof bytes π_{raw}.

3. **Unidirectional Write-Only Channel to the Sanitizer VM:** A second Virtual Machine—the **Sanitizer VM** (Untrusted Proxy)—holds the external network interface. Communi-

cation from the Prover VM to the Sanitizer VM is restricted to a strict one-way, write-only data path implemented via one of three hypervisor primitives:

- A unidirectional `vsock` or `virtio-serial` character device configured for write-only transmission from the Prover VM; or
- A **shared-memory ring buffer** (`ivshmem`) mapped with write permissions on the Prover VM and strictly **read-only** page table permissions on the Sanitizer VM side.

The Prover VM writes the serialized raw proof bytes (x, π_{raw}) into the ring buffer. The Sanitizer VM reads the raw bytes, verifies mathematical validity, applies cryptographic sanitization (Section 3), and publishes the sanitized proof π' to the external network or blockchain.

4. **Memory & Microarchitectural Hardening:** Because witness allocation in standard runtime environments can leave residual artifacts in physical RAM or OS page files, the Prover VM enforces five mandatory hardening controls:

   - **Swap Elimination:** OS swap is completely disabled (or enforced via ephemeral random-key encrypted swap) so plaintext witness vectors never touch persistent storage.
   - **Physical RAM Locking & Zeroization:** Sensitive witness and proving buffers are pinned in physical memory via `mlock()` to prevent hypervisor paging, core dumps (`RLIMIT_CORE = 0`) are disabled, and deterministic memory scrubbing (`zeroize`) overwrites **w** immediately after proof emission.
   - **CPU Core Pinning & SMT Deactivation:** The Prover VM vCPUs are pinned to dedicated physical CPU cores (`vcpupin`), and Simultaneous Multithreading (`SMT` / Hyper-Threading) is disabled to prevent cross-VM L1/L2 cache timing side-channel extraction.
   - **Confidential Computing (Optional TEE Encapsulation):** On supported enterprise hardware, the Prover VM is encapsulated inside a hardware-enforced Trusted Execution Environment (**AMD SEV-SNP** or **Intel TDX**), encrypting VM memory pages so that even a compromised host OS or root hypervisor cannot inspect the prover's RAM.

2.2 Tier-2: Two-Device Physical Air-Gap (Optical Data Diode)

For sovereign root key ceremonies, military/B2G deployments, and high-value cold vaults where sharing a single physical motherboard is unacceptable under TEMPEST or national security mandates, Tier-2 physically separates the Prover and the Sanitizer onto two independent hardware devices:

- **Stateless Air-Gapped Prover Device:** Runs on stripped-down hardware with physically removed wireless/Ethernet controllers and ephemeral RAMdisk storage.
- **Unidirectional Optical Data Diode:** Raw proof payloads are encoded into a fountain-coded (Luby Transform / Reed-Solomon) sequence of high-density animated QR frames rendered on the Prover screen and captured by the Sanitizer's optical camera. Because photons travel strictly from screen to lens, zero backward electromagnetic or software return channel exists.

3 Dual-Track Kleptographic Channel Elimination

Isolating the Prover VM or physical device prevents direct network exfiltration, but does not by itself stop a compromised proving binary from hiding witness bits inside the valid proof π_{raw} sent through the ring buffer or optical diode. Arcanum eliminates subliminal channels inside the Sanitizer VM across both major classes of ZKP systems.

3.1 Track A: Untrusted Proxy Rerandomization for Pairing-Based SNARKs (Groth16)

In Groth16 over a bilinear pairing group $(\mathbb{G}_1, \mathbb{G}_2, \mathbb{G}_T, e, p)$, a raw proof emitted by the Prover VM consists of three group elements:

$$\pi_{\mathsf{raw}} = ([A]_1, [B]_2, [C]_1) \in \mathbb{G}_1 \times \mathbb{G}_2 \times \mathbb{G}_1 \tag{2}$$

Even if a supply-chain trojan inside the Prover VM manipulates the internal blinding scalars $(r, s) \in \mathbb{F}_p^2$ to encode secret bits of the witness w, the Sanitizer VM intercepts π_{raw} before network broadcast:

1. **Pre-Sanitization Verification:** The Sanitizer checks that π_{raw} satisfies the Groth16 bilinear pairing equation for public statement x:

$$e([A]_1, [B]_2) = e([\alpha]_1, [\beta]_2) \cdot e([L_{\mathsf{pub}}(x)]_1, [\gamma]_2) \cdot e([C]_1, [\delta]_2) \tag{3}$$

   and verifies subgroup membership in $\mathbb{G}_1$ and $\mathbb{G}_2$. If verification fails, the payload is dropped immediately.

2. **Fresh Entropy Injection:** The Sanitizer samples two independent, cryptographically secure random scalars $r', s' \leftarrow \$\mathbb{F}_p^*$ from its own entropy pool (with Zero Knowledge of w) and computes the rerandomized proof $\pi' = ([A']_1, [B']_2, [C']_1)$:

$$[A']_1 = r' \cdot [A]_1 \tag{4}$$
$$[B']_2 = (r')^{-1} \cdot [B]_2 + r's' \cdot [\delta]_2 \tag{5}$$
$$[C']_1 = [C]_1 + s' \cdot [A]_1 \tag{6}$$

Theorem 1 (Information-Theoretic Subliminal Channel Destruction): *For any valid Groth16 proof π_{raw} generated by an arbitrarily malicious Prover VM for statement x, the rerandomized proof π' produced by the Sanitizer VM is uniformly distributed over the space of all valid proofs for x, and the mutual information between the private witness W and the published proof Π' conditioned on the public statement X is strictly zero:*

$$I(W; \Pi' \mid X = x) = 0 \tag{7}$$

Proof Sketch: Because $r' \in \mathbb{F}_p^*$ acts as a multiplicative one-time pad in the prime-order group $\mathbb{G}_1$ (assuming $[A]_1 \neq \mathcal{O}$), $[A']_1$ is uniformly distributed in $\mathbb{G}_1 \setminus \{\mathcal{O}\}$ independent of $[A]_1$. Similarly, $s' \in \mathbb{F}_p^*$ additively blinds $[B']_2$ along $[\delta]_2$, while $[C']_1$ is uniquely determined by the bilinear verification equation. Thus, every kleptographic bit encoded in (r, s) is algebraically obliterated. □

3.2 Track B: Deterministic Fiat-Shamir & Channel Binding for STARKs and L2 Verifiers

Hash-based Interactive Oracle Proofs (STARKs, FRI, and Starknet Cairo proofs) lack algebraic group homomorphisms and therefore cannot be externally rerandomized by an untrusted proxy. In standard STARK provers, optional salt grinding and non-deterministic trace padding allow a compromised prover to grind commitments until low-order bits leak secret witness bytes.

Arcanum secures STARK and Cairo proving pipelines through three deterministic constraints:

1. **RFC 6979-Style Deterministic Seed Derivation:** All prover randomness ρ (including FRI blinding and polynomial masking) is derived deterministically via a cryptographic sponge (Poseidon / Rescue-Prime / SHA-3) from the canonical witness commitment and public inputs:
$$\rho_{\mathsf{det}} = \mathsf{Sponge}\big(\mathsf{DomSep} \parallel \mathsf{Commit}(\mathbf{w}) \parallel x \parallel \mathsf{ChannelID}\big) \tag{8}$$

2. **Zero-Grinding Verification in the Sanitizer VM:** All variable proof-of-work or salt fields in the Fiat-Shamir transcript are pinned to canonical zero constants ($\mathsf{salt} = 0^{256}$) or bound directly to the Sanitizer's challenge nonce.

3. **Dual-Modular Redundancy (DMR) Watchdog:** Inside the Prover VM (or across two independent compiler builds, e.g., GCC and Clang), deterministic execution ensures that two honest runs produce bit-for-bit identical proof bytes: $\pi^{(1)}_{\mathsf{raw}} \equiv \pi^{(2)}_{\mathsf{raw}}$. Any divergence induced by a nondeterministic trojan immediately triggers an abort in the Sanitizer VM before network publication.

4 Ecosystem Applications and Target Segments

By combining Tier-1 (Single-Machine Split-VM) and Tier-2 (Physical Optical Diode), Arcanum serves three high-impact deployment segments:

4.1 1. Enterprise Verifiable Backup, Cloud Infrastructure & DeFi (B2B via Split-VM + TEE)

Automated data centers and institutional provers cannot rely on manual optical cameras. Using Arcanum's Tier-1 `KVM/QEMU` Split-VM architecture with `shared-memory ring buffers` and `AMD SEV-SNP` / `Intel TDX`, enterprise backup servers generate periodic zero-knowledge proofs of storage integrity and ransomware-free state transitions without exposing backup decryption keys or witness state to the network-facing management plane.

4.2 2. Everyday Privacy: Kleptography-Resistant ZK-KYC & Delegated Anonymous Spending (B2C via Split-VM)

Regular users require strong isolation on a single personal computer without secondary hardware:

- **Kleptography-Resistant ZK-KYC:** Users prove passport, age, or credential validity locally inside the networkless Prover VM. Even if a third-party identity circuit contains a supply-chain backdoor, the Sanitizer VM strips any subliminal leakage so biometric or identity numbers cannot be exfiltrated inside the proof.

- **Delegated Anonymous Spending Protocol (Cryptographically Controlled Allowance Pools):** Arcanum integrates a privacy-preserving on-chain allowance protocol utilizing proxy signatures and zero-knowledge policy proofs. A Master Delegator locks funds into a cryptographically controlled pool and generates delegated proxy credentials enforcing granular spending policies (e.g., rate limits, merchant categories, or epoch caps). By isolating the Master Delegator key inside the Arcanum Prover VM while proxy users execute anonymous withdrawals on-chain, the delegator retains full cryptographic authority to withdraw pool funds or revoke any compromised proxy without ever exposing the master secret to network-connected wallet software.

4.3 3. Sovereign Public Sector, Defense & Cold Treasury Vaults (B2G via Optical Diode & Qubes OS)

For national critical infrastructure, military command verification, and multi-million-dollar institutional cold treasuries, Arcanum provides Tier-2 two-device Optical Data Diode isolation alongside native `Qubes OS` Split-VM templates for field operators.

5 Implementation Roadmap

1. **Phase 1 — Split-VM Reference Testbed & Circom/R1CS Integration:** Packaging reproducible `KVM/QEMU` and `Qubes OS` VM descriptors, read-only R1CS/witness import pipelines, `vsock` / `shared-memory ring buffer` transport, and Linux memory hardening (`mlock`, `zeroize`, swap suppression, CPU pinning).
2. **Phase 2 — Cryptographic Sanitizer Engine (Groth16 & STARKs):** Rust implementation of the Sanitizer VM proxy rerandomizer over BN254 and BLS12-381 curves ('arkworks') and Deterministic Fiat-Shamir transcript verification for STARK/Cairo provers.
3. **Phase 3 — Optical Data Diode & Delegated Anonymous Spending Modules:** Unidirectional QR fountain-code streaming library and reference circuits for ZK-KYC and Delegated Anonymous Spending pools.

References

[1] A. Young and M. Yung, "The Dark Side of Black-Box Cryptography, or: Should We Trust Capstone?" in *Advances in Cryptology — CRYPTO '96*, Lecture Notes in Computer Science, vol. 1109, Springer, 1996, pp. 89–103.

[2] J. Groth, "On the Size of Pairing-Based Non-interactive Arguments," in *Advances in Cryptology — EUROCRYPT 2016*, Lecture Notes in Computer Science, vol. 9666, Springer, 2016, pp. 305–326.

[3] E. Ben-Sasson, I. Bentov, Y. Horesh, and M. Riabzev, "Scalable, Transparent, and Post-Quantum Secure Computational Integrity," *IACR Cryptology ePrint Archive*, Report 2018/046, 2018.

[4] M. Bellare, K. G. Paterson, and P. Rogaway, "Security of Symmetric Encryption against Mass Surveillance," in *Advances in Cryptology — CRYPTO 2014*, Lecture Notes in Computer Science, vol. 8616, Springer, 2014, pp. 1–19.

[5] T. Pornin, “Deterministic Usage of the Digital Signature Algorithm (DSA) and Elliptic Curve Digital Signature Algorithm (ECDSA),” *Internet Engineering Task Force (IETF)*, RFC 6979, August 2013.